



File No.: EXP202311364

RESOLUTION FOR TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On November 20, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against A.A.A. (hereinafter, the respondent), through the Agreement transcribed below:

<<

File No.: EXP202311364

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On July 25, 2023, the Inspection Area of Health Centers of the Community of Madrid communicated to the Division of Technological Innovation of this Agency a personal data security breach detected during an inspection of the health center located at ***ADDRESS.1, whose owner is A.A.A., with NIF: ***NIF.1

In this regard, the respondent states that they have filed a complaint with the police, which they do not show. When asked about the communication of this security breach to the AEPD, they state that they have not done so.

SECOND: On August 23, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted was admitted for processing.

LEGAL GROUNDS

I

By virtue of the powers conferred by Article 58.2 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47 and 48 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/9

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Article 33 "Notification of a personal data breach to the supervisory authority" of the GDPR establishes:

"1. In the event of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of

personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the likely consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate its possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/9

Corrective measures adopted. This documentation will allow the supervisory authority to verify compliance with the provisions of this article.”

III

In the present case, it is noted that the healthcare center located at ***ADDRESS.1, whose owner is A.A.A., has suffered a security breach, as indicated by the Inspection Area of Healthcare Centers of the Community of Madrid, since the medical records have been archived in digital format since October 2022, because prior to that date they were archived on paper, of which nothing is retained, having suffered a flood.

In this regard, the owner of said healthcare center states that she has filed a complaint with the police, although she does not provide any document to substantiate this.

Furthermore, regarding the communication of this security breach to the Spanish Data Protection Agency, the owner of the healthcare center subject to this sanctioning procedure states that she has not done so.

In light of these circumstances, in accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement, attributable to A.A.A., as the owner of the healthcare center located at ***ADDRESS.1, for violation of Article 33 of the GDPR.

IV

If confirmed, the aforementioned infringement of Article 33 of the GDPR could imply the commission of the infringements typified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/9

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following

infringements are considered serious and shall be subject to a two-year statute of limitations, which imply a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

r) The failure to notify the data protection authority of a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679. (...)"

V

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- g) the categories of personal data affected by the infringement.

In the present case, the leaked data corresponds to identifying data, contact data, and health data.

Furthermore, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- b) The link of the infringer's activity with the processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 33 of the GDPR, allows for an initial sanction of €2,000 (two thousand euros).

VI

Among the corrective powers provided by Article 58 "Powers" of the GDPR, paragraph 2.d) establishes that each supervisory authority may "order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, when appropriate, in a specified manner and within a specified period...".

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/9

The Spanish Agency for Data Protection, in the resolution that concludes this procedure, may order the adoption of measures, as established in Article 58.2.d) of the GDPR and in accordance with what is derived from the instruction of the procedure, if necessary, in addition to imposing a fine.

VII

If the infringement is confirmed, it may be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...".

Specifically, the measure to be imposed in this case would consist of the respondent notifying the AEPD of the security breach that occurred, within one month from the date on which the resolution of this sanctioning procedure is notified to them.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning procedures.

Therefore, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against A.A.A., with NIF: ***NIF.1, for the alleged

infringement of Article 33 of the GDPR, classified in Article 83.4 of the GDPR.

SECOND: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the sanction that may correspond, without prejudice to what results from the instruction, would be TWO THOUSAND EUROS (2,000 €), for the alleged infringement of Article 33 of the GDPR, classified in Article 83.4 of the GDPR.

THIRD: TO APPOINT R.R.R. as instructor and S.S.S. as secretary, indicating that either of them may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/9

FOURTH: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the complainant and its documentation, as well as the documents obtained and generated by the General Subdirectorate for Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FIFTH: TO NOTIFY this agreement to A.A.A., with NIF: ***NIF.1, granting them a hearing period of ten working days to submit allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

If no allegations are made within the stipulated period regarding this initiation agreement, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

As provided in Article 85 of the LPACAP, once a sanctioning procedure has been initiated, if the infringer acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

In accordance with the provisions of Article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for submitting allegations to this initiation agreement; this will entail a reduction of 20% of the sanction to be imposed in this procedure. With the application of this reduction, the sanction would be set at ONE THOUSAND SIX HUNDRED EUROS (1,600 €), resolving the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at ONE THOUSAND SIX HUNDRED EUROS (1,600 €) and its payment would imply the termination of the procedure.

The reduction for voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment is made within the period granted to submit allegations to the initiation of the procedure. The voluntary payment of the amount referred to in the previous paragraph (ONE THOUSAND SIX HUNDRED EUROS (1,600 €) or ONE THOUSAND TWO HUNDRED EUROS (1,200 €)) may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be set at ONE THOUSAND TWO HUNDRED EUROS (1,200 €).

In any case, the effectiveness of any of the aforementioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the imposed sanction, as provided in Article 85.3 of the LPACAP.

In the event that they choose to proceed with the voluntary payment of any of the amounts indicated above (ONE THOUSAND SIX HUNDRED EUROS (1,600 €) or ONE THOUSAND TWO HUNDRED EUROS (1,200 €)), they must make it effective by depositing it into account number ES00 0000 0000 0000 0000 0000 opened in the name of the Spanish Agency for Protection of

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/9

Data in the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it applies.

Furthermore, you must send the proof of payment to the SGID to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of nine months from the date of the initiation agreement or, if applicable, from the draft initiation agreement.

After this period, it will expire, and consequently, the filing of actions will occur, in accordance with the provisions of Article 64.2 of the LOPDGDD.

935-110422

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On March 15, 2024, the party being claimed has proceeded to pay the fine in the amount of 1200 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or appeal in the administrative route against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

FOURTH: In the previously transcribed Initiation Agreement, it was indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the Initiation Agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the infringer acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the latter has been justified,

voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent body to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned on the withdrawal or waiver of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation.”

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202311364, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER A.A.A. to notify the Agency within 1 month from the date this resolution becomes final and enforceable, of the adoption of the measures described in the legal grounds of the Initiation Agreement transcribed in this resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/9

THIRD: NOTIFY this resolution to A.A.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1259-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es